

Manual 34 — ISO/IEC 27701:2025 Privacy Information Management Controlled Implementation

Controlled English master — project-authored implementation guidance

****Baseline:**** ISO/IEC 27701:2025, Edition 2. ISO normative text is not reproduced.

****Boundary:**** implementation guidance does not itself establish certification or legal compliance.

Chapter 01 — Purpose, scope, and controlled-source hierarchy

Establish the PIMS implementation objective, organizational boundary, information classes, products, services, legal entities, jurisdictions, and interfaces included in the program. Maintain a source hierarchy that distinguishes ISO/IEC 27701:2025 concepts, related ISO/IEC 27001/27002 integration, binding privacy law, regulator guidance, contracts, and organization-authored procedures.

****Implementation controls:**** approve scope; identify exclusions and interfaces; assign source owners; date every external source verification.

****Evidence:**** approved scope statement, source register, applicability record, source-verification log.

Chapter 02 — PIMS context and organizational boundaries

Document internal and external conditions that affect privacy information management, including business model, processing scale, data sensitivity, technology, outsourcing, geographic footprint, and stakeholder expectations. Convert context into explicit PIMS design assumptions and review triggers.

****Implementation controls:**** context review at least annually and after material change; link context changes to privacy risk and scope review.

****Evidence:**** context assessment, boundary diagram, change log, review approval.

Chapter 03 — Interested parties and privacy requirements inventory

Identify individuals, customers, regulators, workforce members, suppliers, business partners, auditors, and other parties whose requirements affect the PIMS. Translate relevant requirements into controlled obligations without treating every expectation as law.

****Implementation controls:**** maintain owner, source, applicability, status, and evidence for each requirement.

****Evidence:**** interested-party register, privacy requirements inventory, traceability matrix.

Chapter 04 — PIMS scope determination and applicability record

Define which processing activities, systems, locations, legal entities, services, and third parties are governed by the PIMS. Record rationale for exclusions and dependencies so that certification-readiness or assurance statements cannot exceed the actual managed scope.

****Implementation controls:**** management approval; dependency mapping; scope-to-inventory reconciliation.

****Evidence:**** PIMS scope, applicability record, system/process inventory cross-reference.

Chapter 05 — Leadership, policy, and accountability

Senior management must establish privacy-management direction, approve policy, assign accountability, provide resources, and review performance. Privacy governance should be integrated with enterprise risk and information-security governance rather than operating as an isolated compliance activity.

****Implementation controls:**** approved policy; named accountable executive; governance cadence; documented escalation route.

****Evidence:**** policy, charter, meeting records, decisions, resource approvals.

Chapter 06 — Privacy governance roles and segregation of duties

Define responsibility for privacy risk, processing ownership, system ownership, legal interpretation, security, procurement, incident response, internal audit, and management review. Separate control operation from independent review where practical.

****Implementation controls:**** RACI; delegated authorities; conflict-of-interest review; backup responsibilities.

****Evidence:**** role matrix, job/accountability descriptions, delegation records.

Chapter 07 — Risk and opportunity management for privacy

Use a repeatable method to identify privacy risks arising from processing, technology, people, suppliers, jurisdictions, and lifecycle changes. Assess likelihood and consequence using organization-defined criteria and document treatment decisions.

****Implementation controls:**** approved risk methodology; treatment ownership; acceptance authority; periodic reassessment.

****Evidence:**** privacy risk register, treatment plans, acceptance records, reassessment history.

Chapter 08 — Privacy objectives, measures, and planning

Set measurable privacy-management objectives tied to risk, business priorities, legal/contractual obligations, and continual improvement. Define indicators, target values, owners, reporting frequency, and remediation thresholds.

****Implementation controls:**** management-approved objectives; metric definitions; data-quality checks.

****Evidence:**** objectives register, KPI/KRI definitions, dashboards, action records.

Chapter 09 — Resource, competence, awareness, and communications

Identify required privacy competencies for governance, engineering, operations, procurement, incident response, audit, and leadership. Provide role-specific training and define internal/external communication rules for privacy matters.

****Implementation controls:**** competency criteria; training plans; completion tracking; approved communication routes.

****Evidence:**** competency matrix, training records, awareness evidence, communication plan.

Chapter 10 — Documented-information governance

Control PIMS policies, procedures, registers, workpapers, templates, and evidence so that approved versions are identifiable, protected, retained, retrievable, and changed through authorized processes.

****Implementation controls:**** document ownership; versioning; approval; retention; access control; archival/disposal.

****Evidence:**** document register, approval history, retention schedule, access records.

Chapter 11 — Operational planning and control

Translate privacy requirements and risk treatments into repeatable operational procedures covering data intake, use, sharing, storage, change, retention, deletion, supplier interaction, and exception management.

****Implementation controls:**** operating procedures; control owners; exception approval; change impact review.

****Evidence:**** procedures, operating logs, exception register, change reviews.

Chapter 12 — PII controller responsibilities

Where the organization acts as a PII controller, define how purposes, processing instructions, transparency, individual-rights support, sharing, retention, risk decisions, and processor oversight are governed. Jurisdiction-specific legal duties must remain mapped separately.

****Implementation controls:**** controller-role determination; purpose/processing records; processor oversight; escalation for legal interpretation.

****Evidence:**** controller assessment, processing records, notices, processor governance records.

Chapter 13 — PII processor responsibilities

Where the organization acts as a PII processor, define how customer/controller instructions are received, validated, implemented, changed, and evidenced. Manage subprocessors, confidentiality, security, return/deletion, incident support, and audit obligations according to applicable contracts and law.

****Implementation controls:**** instruction register; contract controls; subprocessor governance; termination process.

****Evidence:**** processor assessment, instruction logs, contracts, subprocessor records, deletion/return evidence.

Chapter 14 — Data-subject rights support processes

Create intake, identity-verification, routing, fulfillment, exception, approval, and evidence processes capable of supporting applicable individual rights. Do not assume one universal rights set or response period across jurisdictions.

****Implementation controls:**** jurisdiction-aware workflow; identity safeguards; deadline tracking; exception/legal review.

****Evidence:**** request log, verification evidence, response record, exception decision.

Chapter 15 — Lawful-purpose and processing-record support

Maintain organization-defined records that identify processing purpose, responsible owner, data categories, data subjects, systems, recipients, jurisdictions, retention, and applicable legal/contractual basis where required. Legal basis determinations must be made by authorized functions.

****Implementation controls:**** processing inventory; purpose-change review; legal mapping; owner certification.

****Evidence:**** processing records, purpose approvals, legal mappings, review history.

Chapter 16 — Privacy by design and privacy by default integration

Integrate privacy requirements into product, service, architecture, procurement, analytics, and change-management lifecycles before deployment. Default configurations should reflect approved privacy objectives and risk decisions.

****Implementation controls:**** design review gates; privacy requirements; architecture review; approval of deviations.

****Evidence:**** design assessments, requirements, architecture decisions, exception approvals.

Chapter 17 — Data minimization, accuracy, retention, and disposal

Limit collection and use to approved purposes and operational need, maintain appropriate accuracy, define retention rules, and implement verifiable deletion, anonymization, return, or archival processes.

Implementation controls: field/data justification; retention schedule; deletion workflow; legal-hold integration.

Evidence: minimization reviews, quality checks, retention rules, disposal logs.

Chapter 18 — Transparency and notice support

Maintain clear, controlled descriptions of relevant processing and ensure notices are reviewed when processing, recipients, technology, geography, or legal requirements materially change.

Implementation controls: notice ownership; change triggers; version control; accessibility review.

Evidence: notice inventory, approvals, publication history, change assessments.

Chapter 19 — Consent and preference-management support

Where consent or user preference is part of the applicable processing model, capture the decision, context, version, time, scope, and withdrawal/change events in a manner that supports auditability. Do not use consent as a default substitute for legal analysis.

Implementation controls: consent criteria; preference store; withdrawal process; downstream propagation.

Evidence: consent records, preference logs, withdrawal evidence, synchronization tests.

Chapter 20 — Supplier, subprocessor, and third-party privacy governance

Apply risk-based privacy due diligence before onboarding third parties and through the relationship lifecycle. Define processing roles, data flows, jurisdictions, contract obligations, security/privacy expectations, incident duties, audit rights, changes, and exit requirements.

Implementation controls: tiering; due diligence; contract review; continuous monitoring; exit controls.

Evidence: assessments, contracts, monitoring records, remediation, termination evidence.

Chapter 21 — Cross-border transfer and jurisdictional mapping support

Map where PII is collected, accessed, stored, supported, and transferred. Route transfer-mechanism and legal-adequacy determinations to qualified legal/privacy functions because requirements differ by jurisdiction and can change.

****Implementation controls:**** data-location inventory; transfer review trigger; approved mechanism record; supplier location change control.

****Evidence:**** transfer map, legal determination, contractual evidence, reassessment record.

Chapter 22 — Security-control integration with ISO/IEC 27001 and 27002

Coordinate privacy controls with the organization's information-security management and technical safeguards. Privacy risk can require controls beyond baseline security, while security controls alone do not establish privacy compliance.

****Implementation controls:**** privacy-to-security control mapping; shared ownership; gap and exception management.

****Evidence:**** crosswalk, risk/control linkage, testing evidence, remediation records.

Chapter 23 — Privacy incident and breach-response support

Integrate privacy assessment into incident response so the organization can determine affected data, people, jurisdictions, contractual obligations, regulator/customer notification requirements, containment, remediation, and evidence preservation. Notification decisions remain jurisdiction-specific.

****Implementation controls:**** privacy incident triage; legal/regulatory decision path; evidence preservation; lessons learned.

****Evidence:**** incident record, impact assessment, notification decision, remediation plan.

Chapter 24 — Records, evidence, and traceability architecture

Define evidence objects that prove governance decisions, control operation, review, exceptions, and corrective actions. Link evidence to requirement, risk, control, owner, system/process, period, and approval where feasible.

****Implementation controls:**** evidence taxonomy; naming/retention rules; access restrictions; integrity checks.

****Evidence:**** evidence index, traceability matrix, retention records, integrity metadata.

Chapter 25 — Monitoring, measurement, analysis, and evaluation

Measure PIMS performance using approved indicators and evaluate whether controls are operating as intended. Distinguish operational metrics from assurance conclusions.

****Implementation controls:**** data owners; metric calculation rules; thresholds; review cadence; corrective-action triggers.

****Evidence:**** dashboards, metric source records, trend analyses, action logs.

Chapter 26 — Internal audit of the PIMS

Plan risk-based internal audits that are sufficiently independent of the activities being reviewed. Define scope, criteria, evidence, sampling, findings, reporting, remediation, and follow-up.

****Implementation controls:**** audit program; auditor competence/independence; finding classification; closure validation.

****Evidence:**** audit plan, workpapers, findings, management responses, closure evidence.

Chapter 27 — Management review

Management review should evaluate PIMS suitability, adequacy, effectiveness, significant risks, audit results, incidents, objectives, resource needs, stakeholder changes, and improvement priorities.

****Implementation controls:**** defined agenda; required inputs; decision/action tracking; accountability.

****Evidence:**** review pack, minutes, decisions, assigned actions, closure records.

Chapter 28 — Nonconformity and corrective action

When a requirement or control fails, contain the issue, assess impact, identify cause, determine systemic implications, implement corrective action, and verify effectiveness before closure.

****Implementation controls:**** finding intake; root-cause method; action ownership; due dates; effectiveness review.

****Evidence:**** nonconformity record, root-cause analysis, remediation evidence, validation result.

Chapter 29 — Continual improvement

Use risk trends, audit results, incidents, metrics, stakeholder feedback, regulatory change, technology change, and lessons learned to prioritize improvements to the PIMS.

****Implementation controls:**** improvement backlog; prioritization criteria; benefit/risk assessment; governance review.

****Evidence:**** backlog, approved roadmap, implementation records, outcome measures.

Chapter 30 — Regulatory and contractual mapping boundary

Map PIMS controls and evidence to applicable laws, regulations, regulator guidance, customer requirements, and contracts without asserting equivalence. A crosswalk is a traceability aid, not proof that satisfying one framework automatically satisfies another.

****Implementation controls:**** source/date/version per mapping; mapping rationale; legal review where required; non-equivalence statement.

****Evidence:**** crosswalk register, rationale, reviewer approvals, change history.

Chapter 31 — Certification-readiness, assurance, and evidence package

Prepare a controlled evidence package that supports internal readiness and external assurance while preserving the boundary between project readiness work and accredited certification. Certification statements may be made only on valid external evidence.

****Implementation controls:**** evidence index; readiness review; gap closure; claim approval.

****Evidence:**** readiness report, evidence pack, gap register, approved external certificates if applicable.

Chapter 32 — Release-time source reverification and implementation roadmap

Immediately before each release, confirm the current ISO/IEC 27701 edition/status, relevant amendments/corrigenda, related standards dependencies, and material regulatory overlays. Freeze source identities before candidate generation and require a new controlled cycle after material change.

****Implementation controls:**** source verification; release checklist; exact source freeze; change-trigger rules; predecessor-order check.

****Evidence:**** source-state record, release checklist, provenance manifest, QA results, publication approval record.

Controlled release statement

This manual is original implementation guidance and does not reproduce ISO normative text. It is not an ISO publication, not an ISO-authorized translation, and does not by itself confer certification or legal compliance. All jurisdiction-specific legal conclusions must be made by appropriately authorized professionals against the applicable facts and current law.